Carnegie Mellon University

Heinz College

INFORMATION SYSTEMS • PUBLIC POLICY • MANAGEMENT

Ethical Penetration Testing – Final Review and Additional Topics

It’s the final countdown

Carnegie Mellon University
Heinz College
INFORMATION SYSTEMS • PUBLIC POLICY • MANAGEMENT

Agenda

- Final Review
- Wi-Fi
- Cloud
- IoT
- ICS
- Car
- What Next?

Let's Talk About the Final

Final Breakdown

- Written Report – 50pts
- Presentation – 30pts
- Number of Systems Compromised – 10pts
- Peer Review – 10pts

Presentation

- One Canvas submission per team before 6:30 on the day of the Final (7 days from today)
- ~5 minutes per person (30 minutes long maximum)
- Schedule (Approximate – See Discord for specific/updated times):
  - Team 1 – 6:30
  - Team 2 – 7:00
  - Team 3 – 7:30
  - Team 4 – 8:00
  - Team 5 – 8:30
  - Team 6 – 9:00
- Wait in the hall or on the weekly Zoom meeting until your team is called in

Presentation Cont.

- Format
  - Overview of the Assessment (Scoping, Systems Discovered, etc.)
  - Walkthrough of Attack Path(s)/Technical Overview (Screenshots and verbal description)
  - Detailed Findings (Screenshot of each finding with verbal description)
  - High Level Recommendations
- Every team member must present
- Screenshot heavy
  - Must be legible and draw the eye to the important information

Presentation Cont.

- Grading for the presentation is based on the following:
  - Length of Presentation – 10pts
  - Format – 10pts
  - Speakers – 10pts

Written Report

- Follow the PWN Challenge format
  - Executive Summary – 10pts
  - Detailed Findings – 10pts
  - Technical Overview – 10pts
  - Technical Details – 10pts
  - Appearance – 10pts

- Make this the best report of the semester by combining all your strengths
- One Canvas submission per team (11 Days from now)

Number of Systems Compromised

- Capturing all flags will earn 5 bonus points
- Ranked scoring based on average number of systems compromised
  - 1st – 10pts
  - 2nd – 9pts
  - 3rd – 8pts
  - 4th – 7pts
  - 5th – 6pts
  - 6th – 5pts
- Less than an average of 3 flags per team member will receive half credit
- No Canvas Submission – Derived from Final Report content

Peer Review

- Available as a quiz from now until the final report is due.
- Rate your fellow team members on a scale from 1-5
- Score is based on your average rating:
  - 5 – 10pts
  - 4 – 8pts
  - 3 – 6pts
  - 2 – 4pts
  - 1 – 0pts
- If you are rating someone lower than a 5, please provide your reasoning
- Individual submissions to Canvas (13 Days from now)

Any Questions?

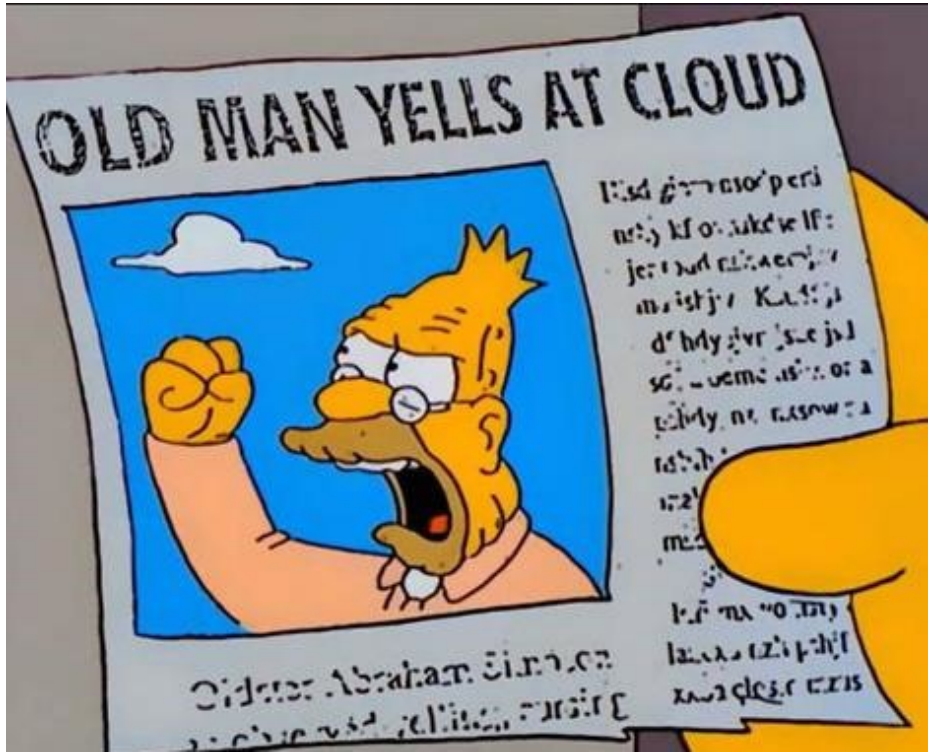
Wireless

Wireless Hacking

- Wireless networks extend beyond the physical perimeter of an organization
- Wireless authentication is hard
  - WEP – Completely broken
  - WPA – Mostly broken
  - WPA2 – Mostly broken
  - WPA3 – Starting to be broken
- Enterprise deployments have additional strengths and weaknesses

The Cloud

Cloud Pentesting



- A major growth field within pentesting
- Testing is very specific to the vendor
  - AWS
  - Azure
  - GCP
  - Oracle
- Some developers do not learn from mistakes
  - Same vulnerabilities we fixed years ago in local systems are repeating themselves

Internet of Things

Hacking IoT Devices

- AKA Internet of Terrible Security
  - Devices made as cheaply as possible
  - Little to no thought given to security
  - Will exist in customer environments for decades to come
  - Some have no upgrade or update functionality
- A combination of Linux and hardware hacking

Industrial Control Systems

ICS/OT Security

- Growing field in need of new ideas
- Most industrial networks were not built by computer or network engineers
- Equipment must last many decades to be worth the investment
- Ideally “air gapped”
- Reality is a mess

Car Hacking

Stunt Hacking

- Be wary of news reports
  - Car Hacking
  - Plane Hacking
  - Drone Hacking
  - Boat Hacking
  - Medical Device Hacking

- There are real risks in all of these technologies but often the reported "hacking" does not scale well or is only applicable in a lab environment

Next Steps

Get Certified

- Practical Network Penetration Tester (PNPT) - https://certifications.tcm-sec.com/pnpt/ ($299 - $399)
- eLearnSecurity Junior Penetration Tester (eJPT) - https://elearnsecurity.com/product/ejpt-certification/ ($200 - $499)
- Offensive Security Certified Professional (OSCP) - https://www.offensive-security.com/pwk-oscp/ ($999 - $1349)
- CompTIA PenTest+ - https://www.comptia.org/certifications/pentest ($370 - $699)
- GIAC Penetration Tester (GPEN) - https://www.giac.org/certifications/penetration-tester-gpen/ ($1699)

Join a Community

- Local communities
  - BarSides - https://twitter.com/barsides
  - Pittsburgh Hackers - https://twitter.com/Pitt_Hackers
- Online Communities
  - Hack The Planet - https://hackplanet.io/
- Conferences
  - Defcon - https://defcon.org/
  - BlackHat - https://www.blackhat.com/
  - WWHF - https://wildwesthackinfest.com/
  - Bsides - http://www.securitybsides.com/

Keep Hacking

- Enjoy the free or cheaply available content now available to everyone.
  - TryHackMe - https://tryhackme.com/
  - Hack the Box - https://www.hackthebox.com/
  - TCM Security - https://academy.tcm-sec.com/
  - INE - https://ine.com/
  - Pentester Academy - https://www.pentesteracademy.com/
  - Sektor7 - https://institute.sektor7.net/

Bonus Assignments: PWN6

- Assignments do not require a full report
- Only need to provide the attack path and proof/local pictures
- Each worth 25 pts
  - 15 pts for the local
  - 10 pts for the proof
- No help will be provided for these bonus assignments

Labs

- TryHackMe Labs
  - https://tryhackme.com/room/wifihacking101
  - https://tryhackme.com/room/iotintro
  - https://tryhackme.com/room/attackingics1

Instructor Review

- Time for you to review me…
- Please take a few minutes to submit the reviews through the smart evals webpage
- You should also have this link in your email:
  - https://cmu.smartevals.com/